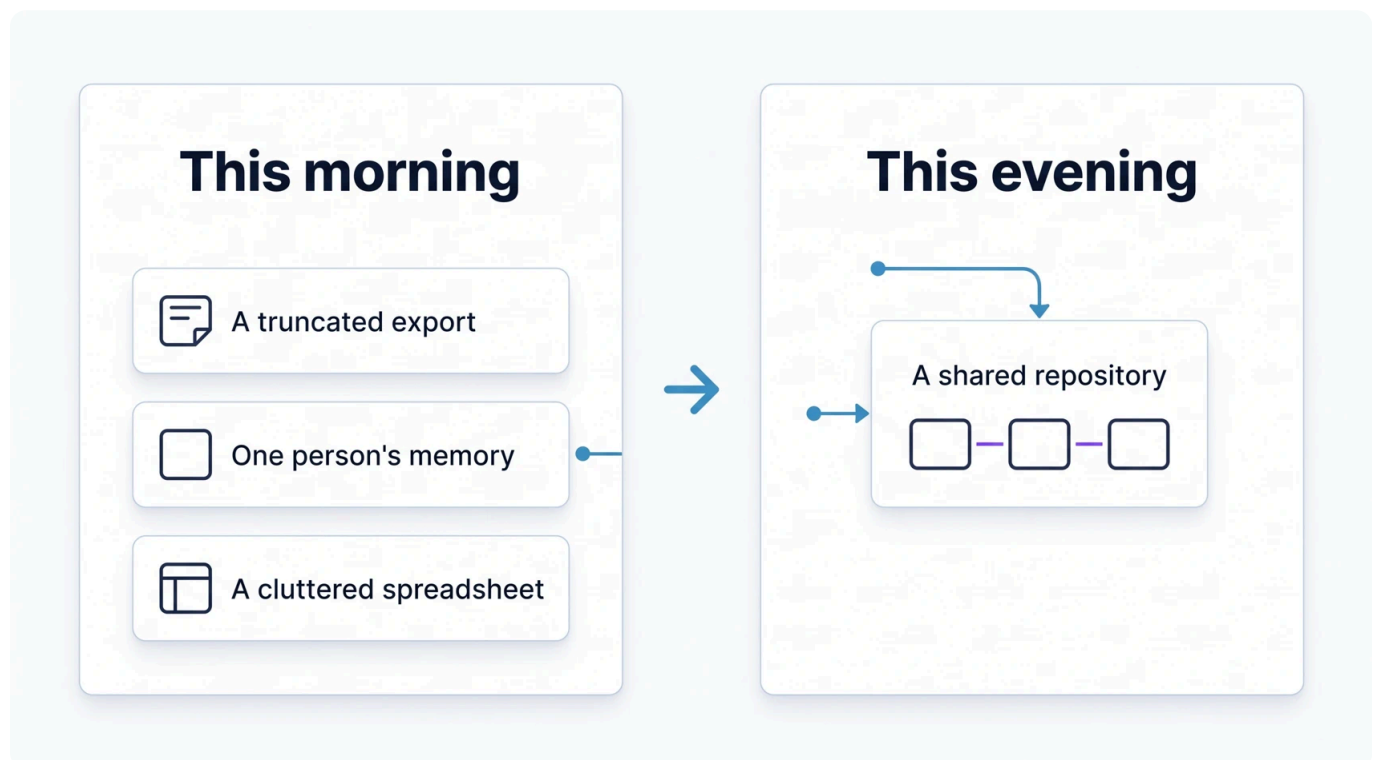


Entering the mapping into CISO Assistant

✓ **Objective:** by the end of the hour, the map of the subsidiary under study exists in the tool



Session objectives

By the end of this lab, the working group's instance contains: the domain of the subsidiary under study, created and named according to the group's MERIDIAN convention, and its owners created by function; at least three business assets entered as primary assets; their supporting assets entered and attached; the security needs filled in for each business asset; and a proof of state exported or captured. What is learned here:

- **Explain** what a GRC tool is, what it brings compared to the morning's spreadsheets, and what it will never do in the analyst's place

- **Transpose** without betraying them the tutorial's notions, business asset, supporting asset, DICT needs, into the tool's objects
- **Apply** the data entry discipline that makes the difference between a governance base and a tidy dumping ground

Prerequisites

- This midday's tutorial: the tables of business assets, supporting assets and DICT ratings for the subsidiary under study, built from the working group's subsidiary pack. This lab creates no new content: it ENTERS what is already built; an empty tutorial table gets filled in first.
- The morning lecture: the maturity trajectory and granularity, which justify starting sober.
- Session 1's governance: each group works on its subsidiary's instance, and the inventory rule arbitrated at the CISO's briefing already applies to data entry: every object will have an owner.

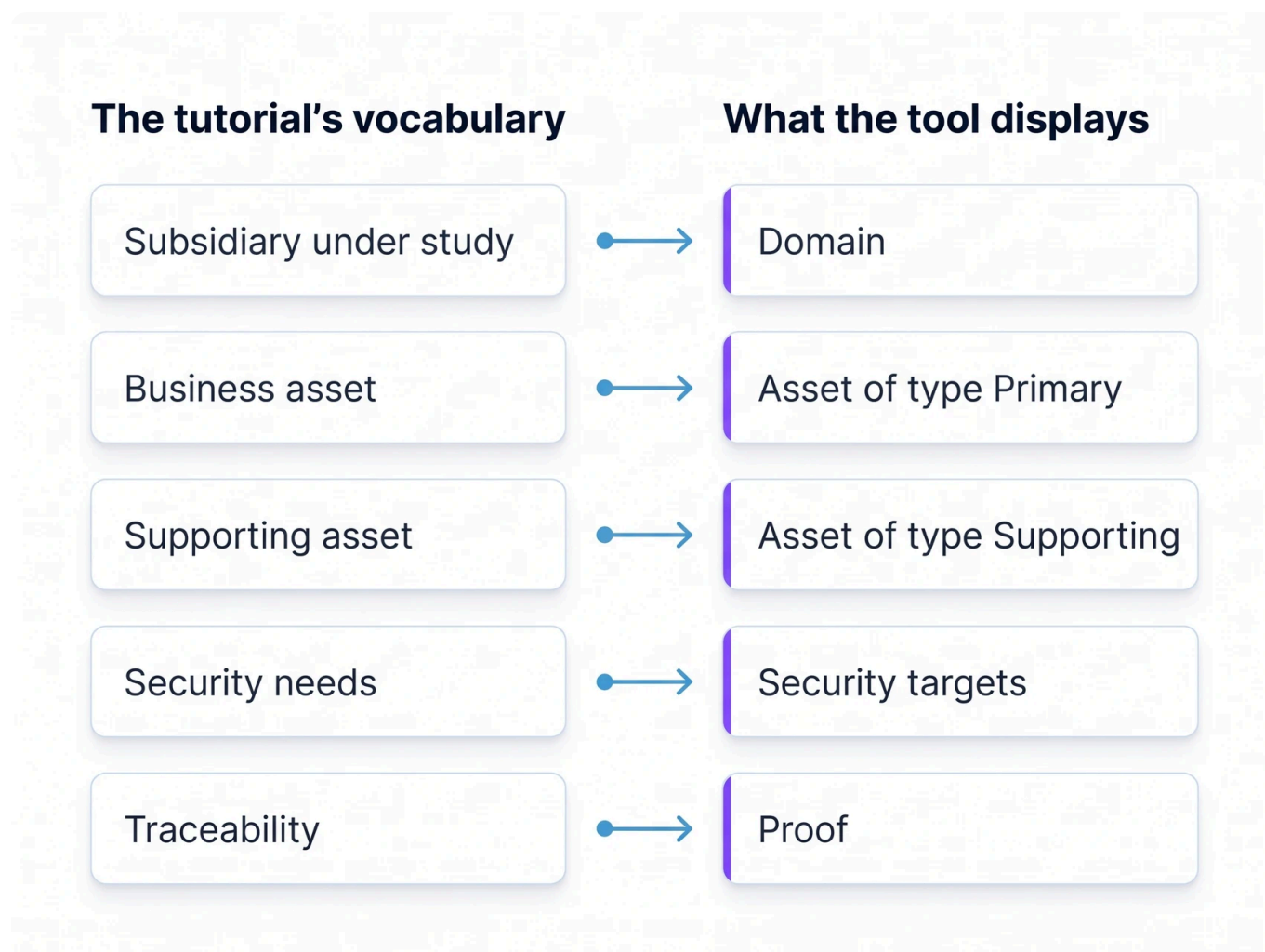
✓ The GRC tool: what it is, and why the group has one

Before entering anything, the object deserves to be understood, because "GRC tool" quickly becomes an everyday word in a CISO's life, and the group's map is not entrusted to an acronym one cannot defend.

The problem first, touched with a finger this morning: spreadsheets. Santé's mapping in a file, Logistique's in a head, the Éducation & Territoires discoveries in a third format; no common vision, no history, no way to know who changed what, and at every request from an auditor or a management team, a week of manual consolidation. A **GRC tool**, for governance, risk and compliance, is the software that centralizes these objects, assets, domains, requirements, assessments, in a single structured base, with links between them, owners, a history. Its mechanics rest on three promises: a common vocabulary imposed by the tool's structure, exactly the one the tutorial laid down; navigable relations, this business asset rests on these supporting assets, no longer juxtaposed lines; and a trace, who entered what and when. Its limit, to be engraved before the first click: the tool structures, it does not think. A badly phrased business asset remains badly phrased in a database; a GRC tool filled without method is a dumping ground with menus. The method is the morning; the tool is only its receptacle.

The group's tool is called CISO Assistant, a free and open-source GRC software published by intuitem, deployed for the module with one instance per working group. Three things to know about its way of ordering the world, because they match the tutorial to the letter, give or take a few labels. First, every object lives in a **domain**: it is the container of an entity, and it is what represents the subsidiary under study. An instance can hold several domains, and a link between assets can cross domains: this is how a dependency whose other end belongs to another entity is modelled, at step 5. The tool also knows "perimeters", but they serve to frame studies, audits or risk analyses, and no asset attaches to them; the word must not mislead. Second, an asset there is one of two types: **Primary**, matching the tutorial's business assets, or **Supporting**, matching the supporting assets and

attached to a parent asset through the field "Is a dependency of ↑". The correspondence is no accident: it is the vocabulary of the ISO 27005 and EBIOS family, seen in the tutorial, that the tool takes up. Third, each primary asset carries **security targets**, confidentiality, integrity, availability and proof, plus three others, authenticity, privacy and safety, which the tutorial did not rate and which stay disabled; it is the tutorial's DICT, with traceability lodging there under the term "proof", and supporting assets automatically inherit the targets of the business assets they carry. A screen label that differs slightly from this course must not stop anyone: the structure is that one, and it is what must be found.



Two ways to access it, as preferred. Either the instance provided by the group, at <https://<instance>.lockbay.eu>, where <instance> is the working group's: medsecure, translog, educonnect or cityadmin, suffixed -a or -b. The complete table appears in the reference dossier. Or a personal deployment of CISO Assistant: the project is open source and its documentation gives the procedure. Both ways produce the same work and the same exported proof of state, and the choice belongs to each person. The interface language is set from the bottom-left menu, next to the login address; the screen labels quoted in this lab are those of the English interface.

The nature of this environment is a lesson of the module as much as an instruction. Its availability is high, its integrity medium, its confidentiality low: it is not a production tool. Only the MERIDIAN case, which is fictional, is entered there. No real data, no person's name, no element from an internship or an employer. Rating a tool's confidentiality before pouring anything into it is exactly the reflex this module installs.

💡 The golden rule of data entry, valid in any GRC tool for an entire career: never enter what has not been decided on paper. The tool records decisions; made in front of the screen, under the pressure of the mandatory field, they are almost always bad.

✓ Step 1: create the domain and lay down the convention (10 minutes)

Each group creates in its instance the domain of its subsidiary, then the owners who will carry its assets.

1. **Create** the domain of the subsidiary under study, under Organization, Domains, with the "Add domain" button (the first of the three buttons at the top right of the list; the second, "Import domain", loads a file, the third, "Inspect", opens a graph view). Name it according to the group convention: MERIDIAN-SANTE, MERIDIAN-LOGISTIQUE, MERIDIAN-EDUCATION or MERIDIAN-TERRITOIRES, in capitals and without accents, the MERIDIAN casing being the group rule and the absence of accents a precaution of interoperability. The "Create IAM groups" box, ticked by default, stays ticked.
2. **Fill in** its description in one useful sentence: the subsidiary's sector and the mission it serves, taken from the tutorial. The editor opens with a double click on the text area. A description is useful if someone outside the group understands what it is about without calling the author.
3. **Create** the owners who will carry the assets, because an asset's "Assigned to" field only accepts existing user accounts: under Organization, Users, "Add user", one fictional address per function from the map of power, on the model [\[email protected\]](#), then, on the created account's page (pencil icon), First name = the function, Last name = the department or entity, because that is how the tool displays it afterwards. The orange message reporting a failed email delivery is normal: the instance sends no mail, and the account is created all the same. These accounts have no rights and nobody logs into them: they are responsibility labels, not accesses.
4. **Note** on the validation sheet the creation time and the author: it is the first line of the history.

Validation criterion: the domain exists, its name respects the convention, its description is useful in the sense above; the owners to come exist as accounts, named by their function.

✓ Step 2: enter the business assets (15 minutes)

1. **Create** as primary assets the subsidiary's business assets from the tutorial, at least three, keeping their exact business phrasing: at TRAMONTANE, "online order taking", not "the e-commerce site server". Under Assets management, Assets, the purple "Add asset" button, first of the four at the top of the list, opens the form:

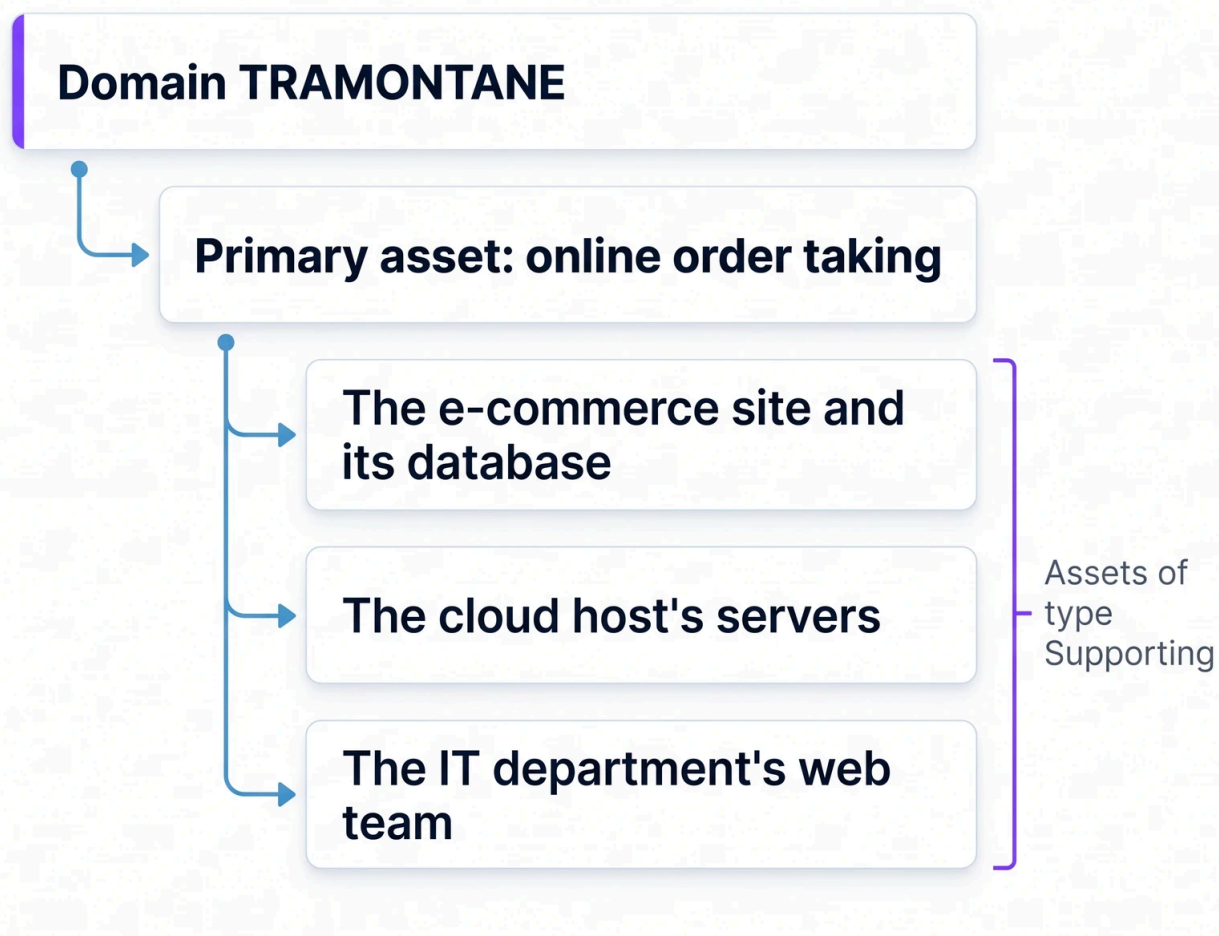
Name, Domain (the one from step 1, to be checked at every entry since the form keeps the previous one), Type "Primary", Class, chosen in a tree with a "Search..." box, "Business Process" for a service or a know-how and "Data" for information, and "Assigned to" with the owner created in step 1.

2. **Fill in** for each one a description of one to two sentences: what the subsidiary would lose if this asset were harmed, that is the best possible description of a business asset.
3. **Resist** the temptation to enter fifteen: the morning's trajectory commands starting with a sober, complete level 1, and the EBIOS RM guide, which returns in session 5, sets the useful order of magnitude, a handful of well-chosen business assets rather than a catalog.

Validation criterion: at least three primary assets, named in business language, each with a description in terms of loss.

✓ Step 3: attach the supporting assets (15 minutes)

1. **Create** as assets of type "Supporting" the supporting assets from the tutorial's table, and **attach** each one to the business asset or assets it carries through the field "Is a dependency of ↑", which accepts several assets: it is this link, not the list, that turns data entry into a mapping. A supporting asset's form has no security targets to fill in: it will inherit them from its business assets from step 4 onwards, and the assets list will display them on its row, which is the quickest check of the attachment.
2. **Cover** the three natures seen in the tutorial, at least one digital supporting asset, one physical, one organizational, and say so through the "Class" field, which stands for it: Software or Data for digital, Devices, Network or Facilities for physical, Users, with its sub-classes Workforce and Service Providers, or Documentation for organizational. The organizational one, the team that administers, the provider that operates, is the one every tool in the world lets slip, because no probe detects it.
3. **Verify** the morning's inventory rule on each object: a named owner in "Assigned to", taken from the map of power in the subsidiary pack, by function, among the accounts created in step 1. An asset without an owner in the tool is exactly the ownerless server from the CISO's briefing, only tidier.



Validation criterion: each business asset has at least one supporting asset attached; the three natures are represented; no asset without an owner.

✓ Step 4: fill in the security needs (10 minutes)

1. **Carry over** onto each business asset the tutorial's DICT ratings, in the "Security targets" section of the primary asset's form (pencil icon on its row, or "Edit" button on its page): availability, integrity, confidentiality, and traceability under its "Proof" label. Each row is first enabled by its toggle, then given its value; a value clicked without the toggle shows but is not saved. Authenticity, privacy and safety stay disabled: the tutorial did not rate them.
2. **Keep** the tutorial's relative scale, without refining it on screen: the tool offers four levels where the tutorial rated three, and the correspondence is fixed before the first entry, negligible 1, notable 2, very important 3, the fourth level staying empty. Do not invent precision the analysis did not produce: false precision born of drop-down menus is the occupational disease of GRC tools.

3. **Indicate** in the asset's description, in one sentence, the justification of the dominant rating: whoever reads the map in six months must find the why next to the how much.
4. **Observe** in the assets list that each supporting asset now displays the targets of its business asset and, when it carries two, the more demanding of the two: it is the inheritance seen in the tutorial on TRAMONTANE's hosted servers, rendered by the tool without anything having been entered on the supporting asset.

Validation criterion: each business asset carries its needs filled in, the dominant rating is justified in one sentence, and the supporting assets display the inherited targets.

✓ Step 5: the inter-subsidiary running thread, and the proof of state (10 minutes)

Each division has stitching work, that of the dependency walked through in tutorial exercise 3. For the Santé and Logistique groups: the "emergency supply" business asset belongs to Santé but rests on Logistique supporting assets, handheld scanners, API, dedicated VLAN, inspection firewall, and on the inventory management system on the Santé side. For the Éducation and Territoires groups: the division's identity directory is a single supporting asset, run by the pooled IT department, which carries the teaching portal on one side and the citizen services platform on the other.

1. **Create** in the instance a second domain, named after the entity on the other side of the boundary (Organization, Domains, "Add domain"), its description saying that it exists only for what crosses the boundary, and enter nothing else in it. For Santé: a MERIDIAN-LOGISTIQUE domain carrying Logistique's supporting assets. For Logistique: a MERIDIAN-SANTE domain carrying the single "emergency supply" business asset, with its targets and its owner. For the division: a domain named after the pooled IT department, carrying the directory, and a domain named after the other subsidiary, carrying its business asset.
2. **Attach** then through "Is a dependency of ↑", whose drop-down list offers the assets of every domain of the instance: the link crosses domains, and the assets list shows on the supporting asset the targets inherited from both sides, the most demanding of each row. The domain files, the description explains: that of the shared supporting asset says in one sentence whom it belongs to and whom it serves.
3. **Export or capture** the final state of the instance, the list of assets and their links: it is the end-of-lab proof, the one the grid below verifies, and the starting point of the next lab, which will extract the group's Top 5 from it. The three buttons to the right of the purple button, at the top of the assets list, provide for it: "Export", as a "CSV file" or an "Excel workbook", to be kept with the validation sheet; "Assets by class", which shows at a glance whether the three natures are represented; and "Inspect", the "Assets explorer", which draws the attachments as a graph, domains included, and gives the most telling capture for the debrief.



Answer keys and assessment criteria — cliquer pour révéler